

Security+ 2.3 · Malicious Updates

Mestre CyberSec — PDF baseado na aula do Professor Messer · 2.3 — Malicious Updates (5:45) · [vídeo original ↗](#) · [YouTube ↗](#)

Update envenenado: atacante compromete o CANAL DE UPDATE (SolarWinds 2020 — 18.000 clientes baixaram update com backdoor). Defesa: code signing (assinatura do update), verify origem, supply chain security.

Highlights que a prova cobra

- SolarWinds: o caso clássico — 18k empresas via 1 update envenenado
- Defesa: code signing + verificação de origem do update

Dicas de prova

- 'software update distributes malware' = supply chain attack / poisoned update

Cenário clássico: Cenário: '18k empresas infected through a trusted vendor update' = supply chain (SolarWinds).

Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Comprometer um fornecedor de software pra atingir todos os clientes dele (ex: SolarWinds):

- A)** Ataque de cadeia de suprimentos
- B)** Watering hole
- C)** Insider
- D)** Zero-day

2. Cenário corporativo (Malicious Updates): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'SolarWinds: o caso clássico — 18k empresas via 1 update envenenado'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: SolarWinds: o caso clássico — 18k empresas via 1 update envenenado...

3. Cenário corporativo (Malicious Updates): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Defesa: code signing + verificação de origem do update'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Defesa: code signing + verificação de origem do update...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Malicious Updates): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: '"software update distributes malware' = supply chain attack / poisoned update'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'software update distributes malware' = supply chain attack / poisoned upda...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Malicious Updates): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Cenário: '18k empresas infected through a trusted vendor update' = supply chain (SolarWinds)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Cenário: '18k empresas infected through a trusted vendor update' = supply c...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Malicious Updates): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'SolarWinds: o caso clássico — 18k empresas via 1 update envenenado'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: SolarWinds: o caso clássico — 18k empresas via 1 update envenenado...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Malicious Updates): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Defesa: code signing + verificação de origem do update'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Defesa: code signing + verificação de origem do update...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Malicious Updates): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'software update distributes malware' = supply chain attack / poisoned update'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'software update distributes malware' = supply chain attack / poisoned update...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Malicious Updates): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Cenário: '18k empresas infected through a trusted vendor update' = supply chain (SolarWinds)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Cenário: '18k empresas infected through a trusted vendor update' = supply c...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Malicious Updates): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'SolarWinds: o caso clássico — 18k empresas via 1 update envenenado'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: SolarWinds: o caso clássico — 18k empresas via 1 update envenenado...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO

- 1) A — Ataque de cadeia de suprimentos.** Supply chain attack compromete um elo confiável (fornecedor) pra alcançar muitos alvos de uma vez.
- 2) D — Implementar a solução correspondente: SolarWinds: o caso clássico — 18k empresas.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Malicious Updates): SolarWinds: o caso clássico — 18k empresas via 1 update envenenado. As demais alternativas configuram violações gra
- 3) B — Implementar a solução correspondente: Defesa: code signing + verificação de orig.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Malicious Updates): Defesa: code signing + verificação de origem do update. As demais alternativas configuram violações graves de confo
- 4) A — Implementar a solução correspondente: 'software update distributes malware' = su.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Malicious Updates): 'software update distributes malware' = supply chain attack / poisoned update. As demais alternativas configuram vi
- 5) C — Implementar a solução correspondente: Cenário: '18k empresas infected through a .** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Malicious Updates): Cenário: '18k empresas infected through a trusted vendor update' = supply chain (SolarWinds).. As demais alternativ
- 6) A — Implementar a solução correspondente: SolarWinds: o caso clássico — 18k empresas.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Malicious Updates): SolarWinds: o caso clássico — 18k empresas via 1 update envenenado. As demais alternativas configuram violações gra
- 7) A — Implementar a solução correspondente: Defesa: code signing + verificação de orig.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Malicious Updates): Defesa: code signing + verificação de origem do update. As demais alternativas configuram violações graves de confo
- 8) B — Implementar a solução correspondente: 'software update distributes malware' = su.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Malicious Updates): 'software update distributes malware' = supply chain attack / poisoned update. As demais alternativas configuram vi
- 9) C — Implementar a solução correspondente: Cenário: '18k empresas infected through a .** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Malicious Updates): Cenário: '18k empresas infected through a trusted vendor update' = supply chain (SolarWinds).. As demais alternativ
- 10) B — Implementar a solução correspondente: SolarWinds: o caso clássico — 18k empresas.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Malicious Updates): SolarWinds: o caso clássico — 18k empresas via 1 update envenenado. As demais alternativas configuram violações gra

